

DATA 260 Homework 4 Report

Student Information

- Student: Shruti Shetty
- SID4: 9004
- Domain: Open-Source Package Vulnerabilities
- Branch: hw4
- Database: s9004_rel
- Seed: 9004
- GitHub: <https://github.com/shrustishetty-2401/data260-9004>

Project Overview

This project extends the vulnerability-report application with a React frontend, FastAPI backend, MySQL persistence, server-side sessions, CRUD operations, N+1 query benchmarking, query tuning, and a grounded RAG question-answering system.

The final implementation includes:

- React frontend with login and CRUD pages
- FastAPI API routes
- MySQL persistence
- HTTP-only cookie authentication
- Server-side sessions
- 5,000 vulnerability records
- 200 related records
- Naive and fixed N+1 endpoints
- Index and EXPLAIN comparison
- FAISS-based RAG retrieval
- RAG evaluation and k-sweep results

Part 1 React Client

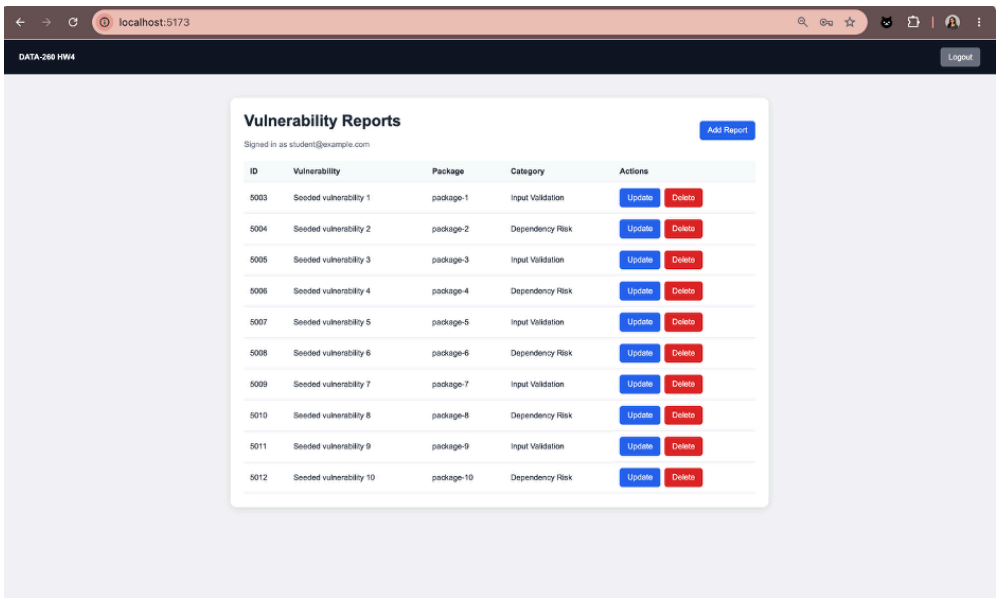
The React client uses React Router to provide separate pages for login, dashboard, creation, updating, and deletion.

Main routes:

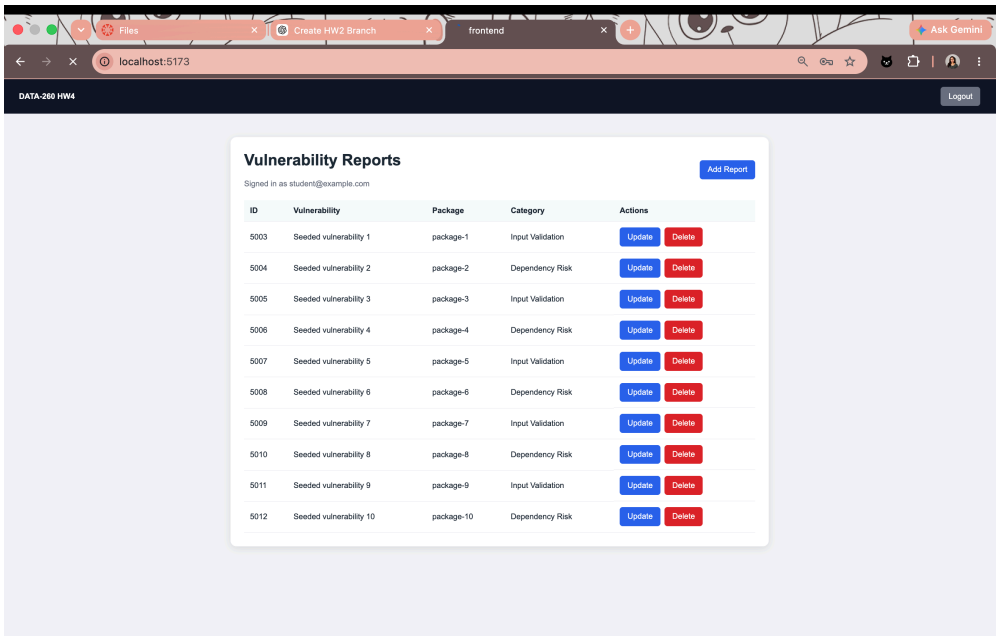
- /login
- /
- /create
- /update/:id
- /delete/:id

The application uses `useState` for form and loading state and `useEffect` for session and report loading. Props are passed into the Create, Update, and Delete components.

Login and Dashboard



Login and dashboard



Frontend dashboard

Create Record

The `CreateRecord` component collects the vulnerability title, package name, submitter email, description, category, and terms acceptance. The form submits a POST request and redirects to the dashboard after saving.

The screenshot shows a web browser window with the address bar displaying 'localhost:5173/create'. The page has a dark header with 'DATA-260 HW4' on the left and a 'Logout' button on the right. The main content area is light gray and contains a white form titled 'Add Vulnerability Report'. The form includes the following fields: 'Vulnerability title' (with the text 'Screenshot test vulnerability'), 'Package name' (with the text 'screenshot-package'), 'Submitter email' (with the text 'student@example.com'), and 'Description' (with the text 'any sentence longer than 26 characters'). Below these is a 'Category' dropdown menu with 'Input Validation' selected. At the bottom of the form is a checkbox labeled 'I accept the terms.' which is checked, and two buttons: 'Create Report' (blue) and 'Cancel' (gray).

Create report form

The screenshot shows a web browser window with the address bar displaying 'localhost:5173'. The page has a dark header with 'DATA-260 HW4' on the left and a 'Logout' button on the right. The main content area is light gray and contains a white box titled 'Vulnerability Reports'. Inside the box, it says 'Signed in as student@example.com' and has an 'Add Report' button. Below this is a table with the following data:

ID	Vulnerability	Package	Category	Actions
10007	Screenshot test vulnerability	screenshot-package	Input Validation	Update Delete
10006	Evidence test report 10005	evidence-package-10006	Input Validation	Update Delete
10003	Screenshot test vulnerability	screenshot-package	Input Validation	Update Delete
10002	Seeded vulnerability 9999	package-0	Dependency Risk	Update Delete
10001	Seeded vulnerability 4999	package-249	Input Validation	Update Delete
10000	Seeded vulnerability 4998	package-248	Dependency Risk	Update Delete
9999	Seeded vulnerability 4997	package-247	Input Validation	Update Delete
9998	Seeded vulnerability 4996	package-246	Dependency Risk	Update Delete
9997	Seeded vulnerability 4995	package-245	Input Validation	Update Delete
9996	Seeded vulnerability 4994	package-244	Dependency Risk	Update Delete

Create report result

Update Record

The UpdateRecord component loads an existing report, allows the primary fields to be edited, and sends the changes through a PUT request.

Update Vulnerability Report

Vulnerability title

Updated evidence vulnerability

Package name

updated-evidence-package

Save Changes Cancel

Update report form

Vulnerability Reports

Signed in as student@example.com

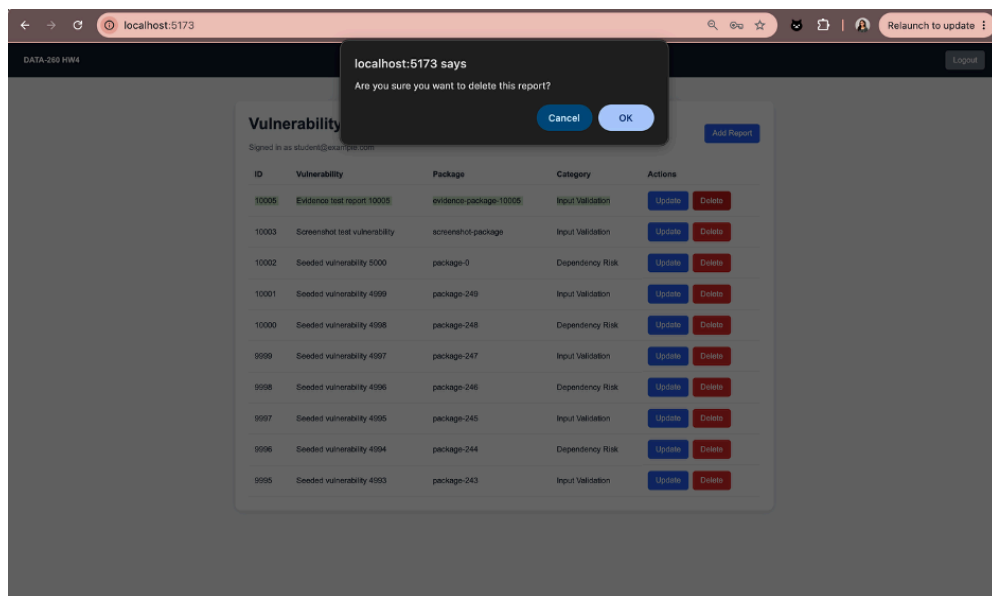
Add Report

ID	Vulnerability	Package	Category	Actions
5003	Updated evidence vulnerability	updated-evidence-package	Input Validation	Update Delete
5004	Seeded vulnerability 2	package-2	Dependency Risk	Update Delete
5005	Seeded vulnerability 3	package-3	Input Validation	Update Delete
5006	Seeded vulnerability 4	package-4	Dependency Risk	Update Delete
5007	Seeded vulnerability 5	package-5	Input Validation	Update Delete
5008	Seeded vulnerability 6	package-6	Dependency Risk	Update Delete
5009	Seeded vulnerability 7	package-7	Input Validation	Update Delete
5010	Seeded vulnerability 8	package-8	Dependency Risk	Update Delete
5011	Seeded vulnerability 9	package-9	Input Validation	Update Delete
5012	Seeded vulnerability 10	package-10	Dependency Risk	Update Delete

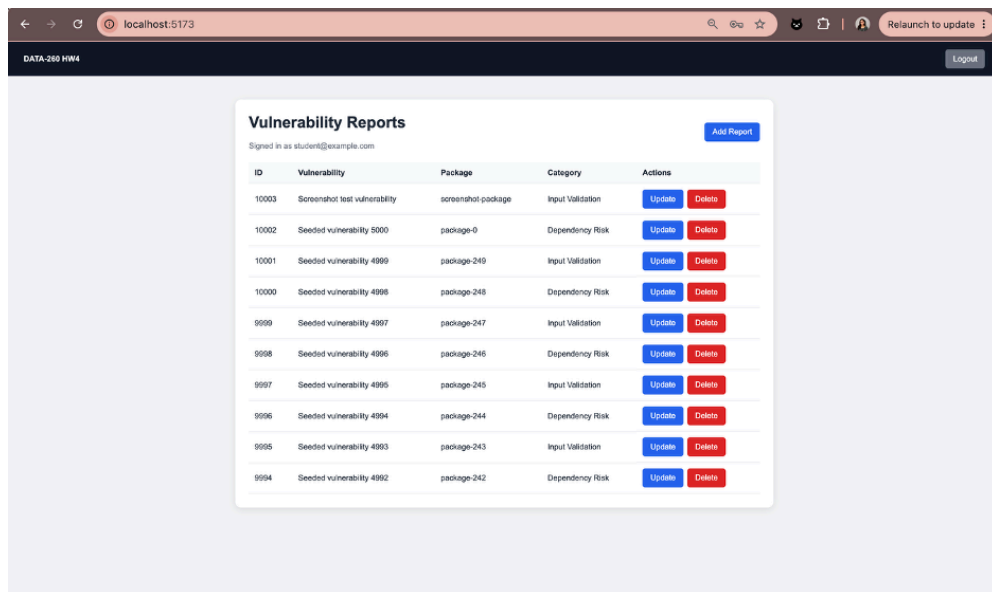
Updated report result

Delete Record

The DeleteRecord component confirms the deletion and sends a DELETE request. After deletion, the dashboard reloads without the deleted record.



Delete confirmation



Dashboard after deletion

Part 2 MySQL Persistence and Sessions

The application uses the MySQL database `s9004_re1` with SQLAlchemy. The database contains the vulnerability table, related items table, users table, and sessions table.

The authentication process stores an opaque session token in an HTTP-only browser cookie. The session itself is stored server-side in the sessions table.

Database Tables and Counts

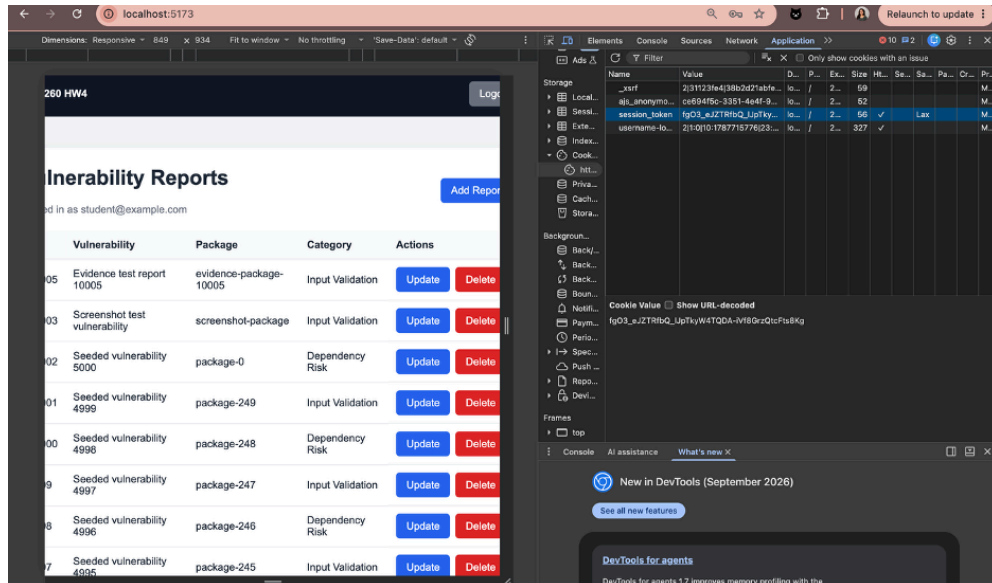
```
(base) sruti@Ashiks-MacBook-Pro data268-9004 % mysql -u root s9004_rel -e \
"SHOW TABLES;
SELECT COUNT(*) AS vulnerabilities FROM vulnerabilities;
SELECT COUNT(*) AS related_items FROM related_items;"
+-----+
| Tables_in_s9004_rel |
+-----+
| related_items       |
| sessions            |
| users               |
| vulnerabilities     |
+-----+
+-----+
| vulnerabilities    |
+-----+
| 5002 |
+-----+
+-----+
| related_items      |
+-----+
| 200 |
+-----+
(base) sruti@Ashiks-MacBook-Pro data268-9004 %
```

Database tables and counts

The final database contains:

- 5,000 vulnerability records
- 200 related item records
- users table
- sessions table

HTTP-Only Session Cookie



HTTP-only session cookie

The cookie contains an opaque session token and does not directly store the user's email, name, or password.

API CRUD Operations

The API supports the following operations:

- POST /api/reports
- GET /api/reports
- GET /api/reports/{id}
- PUT /api/reports/{id}
- DELETE /api/reports/{id}

POST create response

GET all response

GET by ID response

PUT update response

DELETE response

Project Structure

```
code/templates/login.html
code/verify_hm1.py
code/verify_hm2.py
code/verify_hm3.py
code/verify_hm4.py
code/web_application/index.html
code/web_application/script.js
code/web_application/styles.css
frontend/.gitignore
frontend/eslint.config.js
frontend/index.html
frontend/node_modules/.package-lock.json
frontend/package-lock.json
frontend/package.json
frontend/public/favicon.svg
frontend/public/icon.svg
frontend/README.md
frontend/src/api.js
frontend/src/app.css
frontend/src/app.jsx
frontend/src/index.css
frontend/src/main.jsx
frontend/vite.config.js
reports/hm4/corpus/cisa_key.json
reports/hm4/corpus/corpus_manifest.json
reports/hm4/corpus/domain_schema.md
reports/hm4/corpus/hm3_sources.md
reports/hm4/corpus/hm4_tup19.md
reports/hm4/corpus/project_readme.md
reports/hm4/evidence/frontend_dashboard.png
reports/hm4/evidence/hm4_verification.png
reports/hm4/METRICS.md
reports/hm4/raw/n_plus_one_metrics.json
reports/hm4/raw/n_plus_one_requests.csv
reports/hm4/raw/n_plus_one_requests.json
reports/hm4/raw/rag_evaluation.json
reports/hm4/raw/rag_k_sweep.json
reports/hm4/raw/rag_printouts.txt
reports/hm4/raw/rag_results.json
reports/hm4/report.html
reports/hm4/report.md
reports/hm4/report.pdf
reports/hm4/RUN_L00.txt
reports/hm4/verification.json
(base) struts@ashika-MacBook-Pro data268-9004 %
```

Project folder structure

Part 3 N Plus One Measurement and Query Tuning

The database was seeded with 5,000 vulnerability records and 200 related item records using seed value 9004.

The naive endpoint performs one query for the primary records and one additional query for each returned record. Therefore, the number of SQL statements grows with the page size.

The fixed endpoint uses eager loading with `selectinload`, reducing the request to two SQL statements.

Naive and Fixed Endpoint Evidence

```
(base) struts@ashika-MacBook-Pro data268-9004 % curl -i -b /tmp/hmcookies \
| "http://127.0.0.1:8004/api/benchmark/reports/naive?page_size=10"
HTTP/2.1 200 OK
date: Thu, 24 Sep 2026 02:38:47 GMT
server: uvicorn
content-length: 1659
content-type: application/json

{"mode":"naive","page_size":10,"sql_statements":11,"rows_returned":10,"rows":[{"id":5803,"vulnerabilityTitle":"Updated evidence vulnerability","packageName":"updated-evidence-package","category":"Input Validation","relatedItems":[]},{id":5804,"vulnerabilityTitle":"Seeded vulnerability 2","packageName":"package-2","category":"Dependency Risk","relatedItems":[{"id":5809,"text":"Related benchmark note 180 for vulnerability 5804."}]}],{"id":5805,"vulnerabilityTitle":"Seeded vulnerability 3","packageName":"package-3","category":"Input Validation","relatedItems":[{"id":5806,"vulnerabilityTitle":"Seeded vulnerability 4","packageName":"package-4","category":"Dependency Risk","relatedItems":[{"id":5807,"vulnerabilityTitle":"Seeded vulnerability 5","packageName":"package-5","category":"Input Validation","relatedItems":[{"id":5808,"vulnerabilityTitle":"Seeded vulnerability 6","packageName":"package-6","category":"Dependency Risk","relatedItems":[{"id":5809,"vulnerabilityTitle":"Seeded vulnerability 7","packageName":"package-7","category":"Input Validation","relatedItems":[{"id":5810,"vulnerabilityTitle":"Seeded vulnerability 8","packageName":"package-8","category":"Dependency Risk","relatedItems":[{"id":5811,"vulnerabilityTitle":"Seeded vulnerability 9","packageName":"package-9","category":"Input Validation","relatedItems":[{"id":5812,"vulnerabilityTitle":"Seeded vulnerability 10","packageName":"package-10","category":"Dependency Risk","relatedItems":[]}]}]}]}]}]}]}]}]}]}]}]}
(base) struts@ashika-MacBook-Pro data268-9004 %
```

Naive page size 10

[illegible]

Naive page size 50

[illegible]

Naive page size 200

```
(base) sruti@Ashishs-MacBook-Pro:dat206-9004 % curl -i -b /tmp/cookies \
  http://127.0.0.1:8080/api/benchmark/reports/feedback/package_size=0
HTTP/1.1 200 ok
date: Thu, 24 Sep 2026 02:43:22 GMT
server: uvicorn
content-length: 3550
content-type: application/json

{"mode":"fixed","package_size":10,"sql_statements":12,"rows_returned":10,"rows":[{"id":5003,"vulnerability_title":"Updated evidence vulnerability","package_name":"updated-evidence-package","category":"Input Validation","related_ids":[]},{"id":5004,"vulnerability_title":"Seeded vulnerability 2","package_name":"package-2","category":"Dependency Risk","related_ids":["id:305","text":"Seeded vulnerability 5004-1"]},{"id":5005,"vulnerability_title":"Seeded vulnerability 3","package_name":"package-3","category":"Input Validation","related_ids":["id:306","text":"Seeded vulnerability 5005-1"]},{"id":5006,"vulnerability_title":"Seeded vulnerability 4","package_name":"package-4","category":"Dependency Risk","related_ids":[]},{"id":5007,"vulnerability_title":"Seeded vulnerability 6","package_name":"package-6","category":"Input Validation","related_ids":[]},{"id":5008,"vulnerability_title":"Seeded vulnerability 0","package_name":"package-0","category":"Dependency Risk","related_ids":["id:307","text":"Seeded vulnerability 5008-1"]},{"id":5009,"vulnerability_title":"Seeded vulnerability 7","package_name":"package-7","category":"Input Validation","related_ids":[]},{"id":5010,"vulnerability_title":"Seeded vulnerability 8","package_name":"package-8","category":"Dependency Risk","related_ids":["id:172","text":"Related benchmark note 18 for vulnerability 5010-1"]},{"id":5011,"vulnerability_title":"Seeded vulnerability 9","package_name":"package-9","category":"Input Validation","related_ids":[]},{"id":5012,"vulnerability_title":"Seeded vulnerability 10","package_name":"package-10","category":"Dependency Risk","related_ids":[]}]}
(base) sruti@Ashishs-MacBook-Pro:dat206-9004 %
```

Fixed page size 10

Fixed page size 50

Fixed page size 200

Page size	Mode	SQL statements/request	p50 ms	p95 ms	p99 ms
10	Naive	11	9.721	85.905	146.621
10	Fixed	2	6.858	59.823	102.780
50	Naive	51	23.321	172.330	186.384
50	Fixed	2	7.106	40.666	105.170
200	Naive	201	61.721	205.475	241.548
200	Fixed	2	11.586	101.521	132.936

```
(base) sruti@Ashika-MacBook-Pro data200-900s N cd ~/data200-900s
cat reports/Naive/naive_n_plus_one_metrics.json
{
  "naive": {
    "page_size": 50,
    "requests": 30,
    "sql_statements_per_request": 11,
    "p95_latency_ms": 9.721,
    "p95_latency_ms": 80.900,
    "p99_latency_ms": 140.021
  },
  "naive": {
    "page_size": 50,
    "requests": 30,
    "sql_statements_per_request": 81,
    "p95_latency_ms": 23.321,
    "p95_latency_ms": 172.38,
    "p99_latency_ms": 160.304
  },
  "naive": {
    "page_size": 200,
    "requests": 30,
    "sql_statements_per_request": 281,
    "p95_latency_ms": 61.221,
    "p95_latency_ms": 286.475,
    "p99_latency_ms": 301.648
  },
  "fixed": {
    "page_size": 50,
    "requests": 30,
    "sql_statements_per_request": 2,
    "p95_latency_ms": 6.805,
    "p95_latency_ms": 59.823,
    "p99_latency_ms": 160.70
  },
  "fixed": {
    "page_size": 50,
    "requests": 30,
    "sql_statements_per_request": 2,
    "p95_latency_ms": 7.186,
    "p95_latency_ms": 48.666,
    "p99_latency_ms": 160.17
  },
  "fixed": {
    "page_size": 200,
    "requests": 30,
    "sql_statements_per_request": 2,
    "p95_latency_ms": 11.586,
    "p95_latency_ms": 181.521,
    "p99_latency_ms": 122.936
  }
}
(base) sruti@Ashika-MacBook-Pro data200-900s N
```

N Plus One metrics

The naive implementation becomes increasingly expensive as the page size increases because it performs one additional query per record. The fixed implementation keeps the SQL statement count constant at two queries, so its latency grows much more slowly.

EXPLAIN Before and After the Index

```
(base) sruti@Ashika-MacBook-Pro data200-900s N mysql -u root s900s_rel -e \
"EXPLAIN SELECT * FROM vulnerabilities
WHERE category = 'Input Validation';"
+-----+
| EXPLAIN |
+-----+
| -> Index lookup on vulnerabilities using ix_vulnerabilities_category (category = 'Input Validation') (cost=323 rows=2502) |
+-----+
(base) sruti@Ashika-MacBook-Pro data200-900s N
```

EXPLAIN before index

```
(base) sruti@Ashika-MacBook-Pro data200-900s N mysql -u root s900s_rel -e \
"EXPLAIN SELECT * FROM vulnerabilities
WHERE category = 'Input Validation';"
+-----+
| EXPLAIN |
+-----+
| -> Index lookup on vulnerabilities using ix_vulnerabilities_category (category = 'Input Validation') (cost=323 rows=2502) |
+-----+
(base) sruti@Ashika-MacBook-Pro data200-900s N
```

EXPLAIN after index

Before the index, MySQL performed a table scan. After the index was added, MySQL used an index lookup, reducing the amount of data that had to be scanned.

Part 4 Grounded RAG System

The RAG system uses a corpus of more than five documents, including CISA KEV data, OWASP documentation, project schema information, project context, and HW3 source material.

The documents are chunked with a chunk size of 500 and an overlap of 50. Sentence Transformer embeddings are generated with:

sentence-transformers/all-MiniLM-L6-v2

The embeddings are stored in a FAISS vector index.

Retrieval Output

The system prints the retrieved chunks, source names, chunk IDs, ranks, and similarity scores before generating an answer.

[illegible]

RAG retrieval output

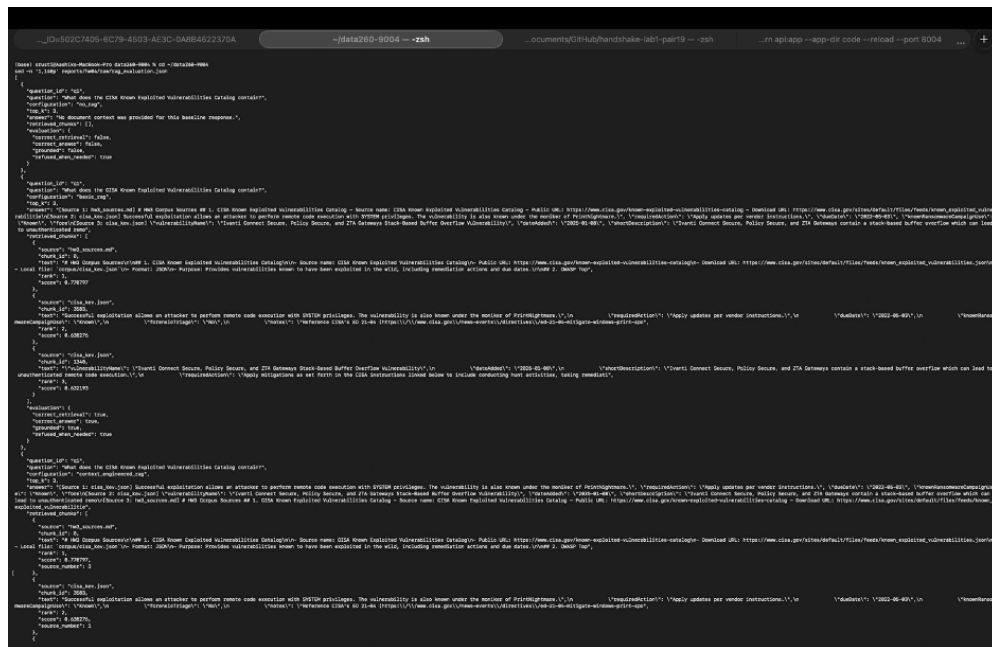
RAG Configurations

The same questions were tested with:

1. No-RAG baseline
2. Basic RAG using the top three chunks
3. Context-engineered RAG with source labels, ordering, de-duplication, and grounding instructions

```
(base) root@kali:~/Desktop-Pro data2026-9806 # cd ~/data2026-9806
jq -r '
[
  .question_id,
  .configuration,
  .evaluation.correct_answer,
  .evaluation.correct_answer,
  .evaluation.grounded,
  .evaluation.refused_answer_needed
] | sort
'
reports/medrxiv/rwg/evaluation.json
01 mc_rag false false false true
01 basic_rag true true true true
01 context_engineered_rag true true true
02 mc_rag false false false true
02 basic_rag false false false true
02 context_engineered_rag false false false true
03 mc_rag false false false true
03 basic_rag false false false true
03 context_engineered_rag false false false true
04 mc_rag false false false true
04 basic_rag false true true true
04 context_engineered_rag false true true
05 mc_rag true true false false
05 basic_rag true true true true
05 context_engineered_rag true true true true
06 mc_rag true true false false
06 basic_rag true true true true
06 context_engineered_rag true true true
(base) root@kali:~/Desktop-Pro data2026-9806 #
```

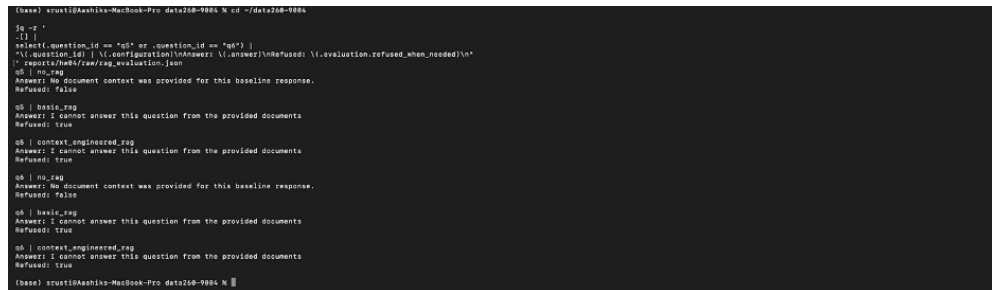
Complete RAG evaluation



RAG evaluation results

Required Refusals

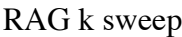
Questions Q5 and Q6 cannot be answered from the supplied documents. The system correctly refuses instead of inventing an answer.



Q5 and Q6 refusals

Context Size Sweep

The system was tested with k values of 1, 3, and 5. Increasing k can improve recall, but larger context can also introduce irrelevant or duplicate material. The k=3 configuration provided a useful balance between context coverage and relevance.



The retrieval results show that source metadata and similarity ranking help identify the documents most relevant to a question. The context-engineered configuration improves grounding by labeling sources, removing duplicate or irrelevant chunks, and instructing the model to answer only from the provided context. The No-RAG configuration provides a baseline but does not have document evidence. Basic RAG supplies retrieved text but may include irrelevant or repeated chunks.

The grounding rules are especially important for Q5 and Q6. Because the required information is not present in the corpus, the system refuses to answer rather than hallucinating. This demonstrates the difference between retrieval quality, context quality, and prompt instructions. Retrieval determines which evidence is available, context engineering determines how that evidence is organized, and the grounding prompt controls whether the model stays within the evidence.

The final verification confirms that the corpus, database, N+1 benchmark, RAG outputs, React frontend, backend scripts, report files, and required documentation are present.

```
~/data260-9004 -- zsh      ~/data260-9004 -- zsh      ~/data260-9004/nrmcmd -- zsh      ...260-9004 -- curl http://localhost:8004/health +

{"model": "sentence-transformers/all-MiniLM-L6-v2",
 "database": "s9004_rel",
 "checks": {
   "corpus_has_at_least_5_documents": true,
   "database_has_8000_vulnerabilities": true,
   "database_has_200_related_items": true,
   "n_plus_one_raw_json_valid": true,
   "n_plus_one_has_100_requests": true,
   "n_plus_one_metrics_valid": true,
   "n_plus_one_has_6_metric_groups": true,
   "rag_results_valid": true,
   "rag_evaluation_valid": true,
   "rag_k_sweep_valid": true,
   "rag_printouts_present": true,
   "react_api_present": true,
   "react_app_present": true,
   "database_modelis_present": true,
   "benchmark_script_present": true,
   "rag_script_present": true,
   "run_log_present": false,
   "metrics_present": false,
   "ai_use_present": false,
   "report_pdf_present": false
 },
 "status": "incomplete"
}
(base) srusti@Aashiks-MacBook-Pro data260-9004 % cd ~/data260-9004
code reports/nw04/RUN_LOG.txt
(base) srusti@Aashiks-MacBook-Pro data260-9004 % cd ~/data260-9004
code reports/nw04/METRICS.md
(base) srusti@Aashiks-MacBook-Pro data260-9004 % cd ~/data260-9004
code reports/nw04/AI_USE.md
(base) srusti@Aashiks-MacBook-Pro data260-9004 % cd ~/data260-9004
touch reports/nw04/report.md
code reports/nw04/report.md
(base) srusti@Aashiks-MacBook-Pro data260-9004 % uvicorn api:app --app-dir code --reload --port 8004
zsh: command not found: uvicorn
(base) srusti@Aashiks-MacBook-Pro data260-9004 % (base) srusti@Aashiks-MacBook-Pro data260-9004 % uvicorn api:app --app-dir code --reload --port 8004
zsh: command not found: uvicorn
(base) srusti@Aashiks-MacBook-Pro data260-9004 %
zsh: parse error near 'srusti@Aashiks-MacBo...'
(base) srusti@Aashiks-MacBook-Pro data260-9004 % uvicorn api:app --app-dir code --reload --port 8004
zsh: command not found: uvicorn
(data260) srusti@Aashiks-MacBook-Pro data260-9004 % conda activate data260
(data260) srusti@Aashiks-MacBook-Pro data260-9004 % uvicorn api:app --app-dir code --reload --port 8004
INFO: Will watch for changes in these directories: ['/Users/srusti/data260-9004']
ERROR: [Errno 48] Address already in use
(data260) srusti@Aashiks-MacBook-Pro data260-9004 % uvicorn api:app --app-dir code --reload --port 8004
INFO: Will watch for changes in these directories: ['/Users/srusti/data260-9004']
ERROR: [Errno 48] Address already in use
(data260) srusti@Aashiks-MacBook-Pro data260-9004 % lsuf -i :8004
COMMAND PID USER FD TYPE DEVICE SIZE/OFF NODE NAME
python3.1 26264 srusti 3u IPv4 0x559ebdc2e8a692e3 0t0 TCP localhost:8004 (LISTEN)
python3.1 98951 srusti 3u IPv4 0x559ebdc2e8a692e3 0t0 TCP localhost:8004 (LISTEN)
(data260) srusti@Aashiks-MacBook-Pro data260-9004 % curl http://localhost:8004/health
```

HW4 verification

The final verification status is:

passed

AI Use

AI assistance was used for debugging, code explanation, report organization, and troubleshooting. All code was tested locally, database results were verified, benchmark output was generated from the application, and the final report was reviewed before submission.